

6.3.7 Lesson Review

Date: 4/13/2026, 3:50:07 AM

Time Spent: 07:18

Score: 100%

Passing Score: 80%



Which practice is the best example of providing users with resources related to AI decisions?

- ☐ Posting a one-time announcement that AI is used somewhere in the service, without offering any ongoing mechanism for questions, corrections, or challenges
- ☒ Creating accessible channels—such as help pages or support workflows—through which users can request explanations, correct data, or contest AI-driven outcomes ✓ Correct
- ☐ Offering a detailed technical white paper intended for experts only, with no simplified guidance for typical users about how AI decisions affect them or what options they have
- ☐ Directing users to a general customer-service inbox that does not distinguish AI-related concerns from billing or product issues and does not track AI-specific complaints

Explanation

Creating accessible channels—such as help pages or support workflows—through which users can request explanations, correct data, or contest AI-driven outcomes is the correct answer. Not only notices but also channels for users to correct or contest outcomes are important. Dedicated, accessible workflows for explanations, corrections, and appeals directly fulfill this requirement.

Posting a one-time announcement that AI is used somewhere in the service, without offering any ongoing mechanism for questions, corrections, or challenges is incorrect. A one-time, vague announcement lacks ongoing support and does not provide a structured way for users to exercise their rights regarding AI outcomes.

Offering a detailed technical white paper intended for experts only, with no simplified guidance for typical users about how AI decisions affect them or what options they have is incorrect. Transparency and resources must be usable by real users. Expert-only documentation without clear, practical guidance and contestation paths falls short of industry expectations.

Directing users to a general customer-service inbox that does not distinguish AI-related concerns from billing or product issues and does not track AI-specific complaints is incorrect. This does not meaningfully support contesting AI decisions or tracking AI-related risks. You should provide more targeted, accountable channels.

Related Content



6.3.1 Common Themes in AI Regulation



6.3.5 External Compliance Impacts

resources\questions\q_common_themes_in_ai_regulation_08.question.xml

A regional bank is preparing to roll out an AI system that flags potentially fraudulent transactions. Before launch, the bank hires an independent firm to conduct a third-party compliance evaluation.

Which action BEST reflects the evaluator's primary role in this context?

- ☐ Writing the bank's AI policies and procedures so that procurement and risk committees have less work to perform during internal reviews.
- ☒ Independently testing the AI system, gathering evidence on how it operates, and forming an objective opinion about its alignment with legal, industry, and internal requirements. ✓ Correct
- ☐ Interviewing the bank's AI developers to help them design new fraud-detection features that improve model innovation.
- ☐ Approving the bank's AI rollout plan and assuming legal liability for any future compliance failures related to the fraud-detection model.

Explanation

Independently testing the AI system, gathering evidence on how it operates, and forming an objective opinion about its alignment with legal, industry, and internal requirements is the correct answer. A third-party evaluator is neither the developer nor the purchaser. Their role is to independently test systems, review controls, and gather evidence, then provide a reasoned opinion on how well the AI aligns with legal obligations, standards, contractual requirements, and internal policies. They validate, but do not operate, the AI.

Interviewing the bank's AI developers to help them design new fraud-detection features that improve model innovation is incorrect. Evaluators may interview staff, but their goal is not feature design or innovation. They assess whether existing controls and behaviors meet specified requirements.

Approving the bank's AI rollout plan and assuming legal liability for any future compliance failures related to the fraud-detection model is incorrect. Evaluators do not "approve" deployment or assume legal liability. They inform decisions; responsibility for using the AI and managing compliance remains with the organization.

Writing the bank's AI policies and procedures so that procurement and risk committees have less work to perform during internal reviews is incorrect. Evaluators might review policies but typically do not write them to reduce internal workload. Policy ownership and governance stay with the organization's leadership and risk functions.

Related Content

 6.3.1 Common Themes in AI Regulation

 6.3.5 External Compliance Impacts

resources\questions\q_external_compliance_impacts_03.question.xml

Question 3

✓ Correct

A U.S.-based startup offers an AI-powered hiring platform to companies in Germany and France. The system screens résumés and automatically rejects candidates who don't meet certain criteria.

The startup has no office in Europe and assumed EU laws would not apply. A German client warns them that their system is considered "high-risk" under the EU AI Act.

Which action BEST aligns with the startup's obligations under the EU AI Act?

- ☒ Classify the hiring system as high-risk, implement required controls (documentation, data governance, testing, human oversight), and complete the conformity assessment for access to the EU market. ✓ Correct
- ☐ Keep operating as usual because the startup is not physically located in the EU, and the EU AI Act only applies to companies headquartered in EU Member States.
- ☐ Stop offering the platform to EU customers and keep all current EU client data, since the Act only applies to future deployments of AI systems.
- ☐ Implement a full AI Management System based on ISO/IEC 42001 and publish an internal AI code of ethics for employees.

Explanation

Classifying the hiring system as high-risk, implementing required controls (documentation, data governance, testing, human oversight), and completing the conformity assessment for access to the EU market is the correct answer. The EU AI Act would apply to this scenario and categorize this as high risk. AI systems used in employment decisions, such as automated candidate screening and rejection, are categorized as high-risk because they significantly affect individuals' rights and opportunities. For high-risk AI, providers must implement extensive controls and put in place post-market monitoring. They must also undergo a conformity assessment before placing the system on the EU market.

Implementing a full AI Management System based on ISO/IEC 42001 and publishing an internal AI code of ethics for employees is incorrect. The question asks what best aligns with obligations specifically under the EU AI Act. The Act requires risk-based categorization, technical and organizational measures, documentation, and conformity assessments for high-risk systems. Merely adopting ISO/IEC 42001 does not ensure compliance with the Act's requirements. This step alone does not adequately address the startup's regulatory responsibilities for placing a high-risk AI system on the EU market and would leave significant legal gaps under the EU AI Act.

Stopping offering the platform to EU customers and keep all current EU client data, since the Act only applies to future deployments of AI systems, is incorrect. Ceasing future sales might reduce ongoing exposure but the startup still has existing EU customers actively using the hiring platform, so compliance duties under the EU AI Act remain for those deployments (such as documentation and post-market monitoring). Additionally, retaining all EU client data without reviewing legal bases and data governance may introduce further regulatory risks, including under other EU laws.

Keeping operating as usual because the startup is not physically located in the EU is incorrect. The EU AI Act applies extraterritoriality to providers that place AI systems on the EU market or whose systems are used within the EU, regardless of where the company is headquartered. The startup offers its AI hiring platform to customers in Germany and France, meaning the system is effectively placed on the EU market and used in Member States. This choice ignores the Act's fundamental structure and would expose the company to potentially severe penalties for noncompliance.

Related Content



6.3.2 Important AI Compliance Frameworks

resources\questions\q_important_ai_compliance_frameworks_05.question.xml

Question 4

✔ Correct

Jordan is a marketing specialist at a mid-sized company. The company recently rolled out an approved internal generative AI assistant that is integrated with single sign-on and has clear guidelines for handling customer data.

Jordan finds a powerful free AI chatbot online and starts pasting draft customer proposals into it, because it gives better ideas and is faster than the internal tool. The company's AI policy states that only vetted and approved AI tools may be used with customer-related information.

Which action BEST aligns with the organization's AI policy on sanctioned vs. unsanctioned AI?

- ☐ Ask coworkers to start using the free chatbot as well to increase team productivity.
- ☐ Use both the free chatbot and the internal assistant to compare outputs and choose the best one.
- ☐ Continue using the free chatbot but remove customer names from the proposals.
- ☒ Stop using the free chatbot and migrate this work to the approved internal AI assistant. ✓ Correct

Explanation

Stopping the use of the free chatbot and migrating this work to the approved internal AI assistant is the correct answer. This aligns with a sanctioned vs. unsanctioned AI policy. Sanctioned tools have been vetted for security, privacy, and compliance and are supported by IT and legal. Because the policy explicitly limits customer-related information to approved tools, Jordan must discontinue using the unsanctioned chatbot and use only the internal assistant. This applies the policy by choosing the approved option rather than relying on shadow AI.

Continuing to use the free chatbot but removing customer names from the proposals is incorrect. Removing names is not enough to make this compliant. Customer proposals usually still contain sensitive business information, even without explicit identifiers. The policy states that only vetted tools may be used with customer-related information. Jordan would still be sending potentially confidential content to an unsanctioned third-party service with unknown storage, training, and sharing practices. This action continues shadow AI behavior and ignores the company's policy.

Using both the free chatbot and the internal assistant to compare outputs and choose the best one is incorrect. This option deepens the policy violation. Even if the internal tool is used in parallel, copying proposals into the external chatbot still violates the rule restricting customer-related information to sanctioned tools. Comparing outputs might improve creativity, but it undermines the key purpose of AI policy: ensuring that security, privacy, and compliance requirements are consistently applied. Jordan should rely on the vetted assistant and, if its capabilities are lacking, work through proper channels to request enhancements or new approved tools.

Asking coworkers to start using the free chatbot as well to increase team productivity is incorrect. This makes the problem worse by expanding shadow AI usage across the team. Instead of aligning with the sanctioned AI strategy, Jordan would be encouraging broader noncompliance and increasing the organization's exposure to data leakage and regulatory risk. Productivity benefits do not override policy requirements.

Related Content



6.3.3 Organizational AI Policies

resources\questions\q_organizational_ai_policies_04.question.xml

Question 5

✓ Correct

An AI startup offers a generative model that drafts loan denial letters for banks. The company claims in its marketing that the system "fully prevents discriminatory outcomes" and "meets all major regulatory requirements."

A cyber insurance underwriter is reviewing the startup's application and asks for evidence of its AI controls and testing.

Which action BEST helps reduce both the startup's legal exposure and its cyber insurance risk in this situation?

- ☐ Provide the underwriter with only high-level architecture diagrams and insist that specifics of testing and controls are confidential trade secrets.
- ☐ Temporarily remove all references to fairness and regulatory compliance from marketing materials while continuing to rely solely on internal, informal testing results.
- ☐ Add a broad disclaimer to the website stating that customers are responsible for all regulatory compliance, without changing any existing AI testing or documentation practices.
- ☒ Commission an independent third-party assessment that documents fairness testing, data handling practices, and security controls, and update marketing claims to match the validated results. ✓ Correct

Explanation

Commissioning an independent third-party assessment that documents fairness testing, data handling practices, and security controls, and updating marketing claims to match the validated results, is the correct answer. Independent third-party assessments can demonstrate control maturity, fairness testing, and security measures. This documentation supports accurate, non-misleading claims and reduces the chance of deceptive practice allegations. For cyber insurers, validated controls and evidence-based testing often lead to better underwriting decisions and potentially more favorable terms, as risk is easier to quantify and appears more manageable.

Adding a broad disclaimer to the website stating that customers are responsible for all regulatory compliance, without changing any existing AI testing or documentation practices, is incorrect. Disclaimers do not eliminate legal exposure if marketing claims are misleading or unsupported. Regulators and customers may still view overstated or unverified fairness and compliance claims as deceptive, regardless of contractual language. Without independent evidence and alignment between claims and controls, both legal and insurance risks remain elevated.

Providing the underwriter with only high-level architecture diagrams and insisting that the specifics of testing and controls are confidential trade secrets is incorrect. Refusing to share meaningful evidence of testing and controls undermines confidence. Underwriters need objective information to assess risk; lack of transparency may result in higher premiums, restrictive terms, or even denial of coverage. It also does nothing to correct potentially misleading external claims about the AI's capabilities.

Temporarily removing all references to fairness and regulatory compliance from marketing materials while continuing to rely solely on internal, informal testing results is incorrect. Removing marketing claims can reduce some exposure going forward, but it does not address prior statements or the underlying control gaps. Continuing with only informal, internal testing leaves the organization without credible, third-party evidence that its safeguards work. Insurers will still lack the detailed proof they need to accurately underwrite the risk.

Related Content

 6.3.1 Common Themes in AI Regulation

 6.3.5 External Compliance Impacts

resources\questions\q_external_compliance_impacts_05.question.xml

Which practice best reflects ensuring that AI-related claims match the system's real capabilities?

- ☐ Using user studies and pilot feedback as the primary basis for claims, without requiring that those findings be confirmed by structured, repeatable testing
- ☐ Allowing product teams to describe AI features as "highly accurate" or "low risk" based on internal experience, even if no formal validation has been completed
- ☐ Emphasizing the most favorable performance benchmarks in external communications, while mentioning limitations only in detailed technical reports
- ☒ Aligning marketing materials and user interfaces with verified test results and avoiding promises that go beyond demonstrated performance

✔ Correct

Explanation

Aligning marketing materials and user interfaces with verified test results and avoiding promises that go beyond demonstrated performance is the correct answer. Organizations should avoid overstating AI capabilities and ensure that all disclosures are accurate, aligning marketing, documentation, and interfaces with verified results.

Emphasizing the most favorable performance benchmarks in external communications, while mentioning limitations only in detailed technical reports is incorrect. While mentioning limitations somewhere is better than not at all, overall disclosures must be accurate and not misleading. Highlighting only best-case metrics in prominent materials while burying important constraints risks is deceptive.

Allowing product teams to describe AI features as "highly accurate" or "low risk" based on internal experience, even if no formal validation has been completed, is incorrect. Internal experience alone is not enough. Claims should be supported by evidence and verification. Using qualitative impressions without formal validation can lead to unsubstantiated or exaggerated statements.

Using user studies and pilot feedback as the primary basis for claims, without requiring that those findings be confirmed by structured, repeatable testing, is incorrect. While user studies and pilots are useful, validated, documented results are critical and necessary.

Related Content

 6.3.1 Common Themes in AI Regulation

 6.3.5 External Compliance Impacts

resources\questions\q_common_themes_in_ai_regulation_06.question.xml

Question 7

✓ Correct

How do organizations commonly use the OECD AI Principles when developing their internal AI policies?

- ☐ They apply the Principles to low-risk AI systems while relying on ISO and NIST frameworks for any high-risk or safety-critical applications.
- ☒ They reference the Principles to anchor their policies and ethics reviews in shared values like human rights, transparency, robustness, and accountability. ✓ Correct
- ☐ They use the Principles as a mandatory checklist of technical controls that must be implemented exactly as written to avoid regulatory fines.
- ☐ They ignore the Principles in corporate policy work because the guidance is purely academic and not intended for practical use in real-world AI.

Explanation

They reference the Principles to anchor their policies and ethics reviews in shared values like human rights, transparency, robustness, and accountability is the correct answer. The Principles emphasize inclusive growth, human rights, transparency, robustness, and accountability. Organizations use them as a value framework that explains why specific controls, assessments, and governance structures are needed, helping gain alignment across product, legal, and engineering teams and improving understanding of responsible AI goals.

They use the Principles as a mandatory checklist of technical controls that must be implemented exactly as written to avoid regulatory fines is incorrect. The OECD AI Principles are nonbinding guidance and do not directly impose fines or define enforceable obligations. Regulators and organizations may translate these principles into specific requirements, but the Principles themselves are high-level and flexible. Treating them as a rigid, penalty-backed control catalog misrepresents their purpose and legal status.

They apply the Principles to low-risk AI systems while relying solely on ISO and NIST frameworks for any high-risk or safety-critical applications is incorrect. The Principles are not restricted to low-risk systems and are not designed to be segmented by risk in this way. They express broad values applicable across AI uses. For high-risk or safety-critical applications, organizations may rely more heavily on detailed frameworks like ISO standards or NIST AI RMF, but these typically complement, rather than replace, OECD-inspired value commitments.

They ignore the Principles in corporate policy work because the guidance is purely academic and not intended for practical use in real-world AI is incorrect. Many national strategies and corporate codes of conduct refer to the OECD Principles. They are used in real-world policy, ethics reviews, and governance efforts, not just academic debate. Far from being ignored, they help explain the rationale for controls and support the adoption of responsible AI practices making them practically significant in organizational AI policy.

Related Content



6.3.2 Important AI Compliance Frameworks

resources\questions\q_important_ai_compliance_frameworks_02.question.xml

A Fintech company uses an AI model to prioritize fraud investigations on credit card transactions.

During a third-party compliance evaluation, the assessor focuses on independent model validation and asks how the company confirms that performance metrics are reliable in real-world conditions.

Which approach BEST demonstrates effective independent model validation for this fraud model?

- ☒ Re-running the original training and testing process on the same datasets, checking that performance metrics are reproducible, and validating results on previously unused samples. ✓ Correct
- ☐ Monitoring overall fraud losses over time and assuming the model is valid as long as total losses do not increase significantly, without running any structured model-level tests.
- ☐ Comparing the model's fraud scores to a small subset of historical cases selected by one fraud analyst, without documenting the selection method, metrics, or thresholds.
- ☐ Asking the original model development team to review their own code and confirm via email that the model still performs as expected on the training data they originally used.

Explanation

Re-running the original training and testing process on the same datasets, checking that performance metrics are reproducible, and validating results on previously unused samples is the correct answer. Independent model validation may replicate training/testing, verify correct data splits, and test performance on unused samples. This approach checks that metrics are reproducible and meaningful under realistic conditions, aligning closely with third-party expectations for robust validation.

Asking the original model development team to review their own code and confirm via email that the model still performs as expected on the training data they originally used is incorrect. Having developers validate their own work lacks independence and focuses only on training data. It doesn't address overfitting, data leakage, or real-world robustness, all of which evaluators care about when reviewing model risk and compliance.

Comparing the model's fraud scores to a small subset of historical cases selected by one fraud analyst, without documenting the selection method, metrics, or thresholds is incorrect. Using a small, analyst-selected subset without documentation introduces selection bias and poor reproducibility. Evaluators expect structured, transparent validation with defined metrics, sampling methods, and thresholds so results can be trusted and repeated.

Monitoring overall fraud losses over time and assuming the model is valid as long as total losses do not increase significantly, without running any structured model-level tests is incorrect. Monitoring aggregate fraud losses is too coarse and influenced by external factors (e.g., market changes, new attack patterns). Without targeted model-level tests, this does not demonstrate that the model's performance metrics are valid or stable for compliance purposes.

Related Content

 6.3.1 Common Themes in AI Regulation

 6.3.5 External Compliance Impacts

resources\questions\q_external_compliance_impacts_08.question.xml

According to policy guidance, when is using a public model generally MOST appropriate?

- ☐ When processing sensitive health or financial records that require strict isolation and customer-managed encryption keys.
- ☒ When handling low-risk tasks like brainstorming generic marketing content, provided the provider offers strong data-use guarantees. ✓ Correct
- ☐ When training models on restricted internal source code and unreleased product information that must never leave the organization's trust boundary.
- ☐ When the organization wants to avoid any contractual commitments and prefers that providers can freely retain and train on all prompts and outputs without limitation, thereby maximizing innovation potential.

Explanation

When handling low-risk tasks like brainstorming generic marketing content, provided the provider offers strong data-use guarantees is the correct answer. Low-risk uses (e.g., generic marketing) are suitable for public models with solid data-use guarantees.

When processing sensitive health or financial records that require strict isolation and customer-managed encryption keys is incorrect. Industry standards recommend private models for high-risk, sensitive data.

When training models on restricted internal source code and unreleased product information that must never leave the organization's trust boundary is incorrect. Restricted and highly sensitive data should stay within private, tightly controlled environments.

When the organization wants to avoid any contractual commitments and prefers that providers can freely retain and train on all prompts and outputs without limitation, thereby maximizing innovation potential is incorrect. Policy stresses data-use controls and contractual assurances, not unrestricted provider use of organizational data.

Related Content



6.3.3 Organizational AI Policies

resources\questions\q_organizational_ai_policies_02.question.xml

Which description BEST reflects how risk classification should be applied to AI use cases in practice?

- ☐ Assigning risk levels only according to the size of the training dataset, assuming larger datasets automatically create higher risk for every model
- ☐ Rating AI tools solely on how complex their algorithms are, because more complex models are always more dangerous than simpler ones and must be controlled carefully
- ☐ Grouping AI systems by how they are marketed to customers so that all "advanced" features are treated as low risk
- ☒ Classifying AI models based on their intended use, data sensitivity, and potential effects on individuals' safety or rights ✓ Correct rights

Explanation

Classifying AI models based on their intended use, data sensitivity, and potential effects on individuals' safety or rights is the correct answer. This aligns with the best practice of maintaining a register that notes intended use, using data, determining whether safety or rights are impacted, and then classify risk accordingly to guide controls and oversight.

Grouping AI systems by how they are marketed to customers so that all "advanced" features are treated as low risk is incorrect. Marketing labels do not reflect real risk. It is important to tie risk to how AI is used, what data it relies on, and whether it affects safety or rights, not to promotional descriptions.

Assigning risk levels only according to the size of the training dataset, assuming larger datasets automatically create higher risk for every model is incorrect. Dataset size alone does not determine risk. Sensitivity and context of use matter more; a smaller but sensitive dataset can be higher risk than a larger, non-sensitive one.

Rating AI tools solely on how complex their algorithms are, because more complex models are always more dangerous is incorrect. Complexity does not always equal danger. Practical risk classification is tied to impact and data, not just algorithmic complexity.

Related Content

 6.3.1 Common Themes in AI Regulation

 6.3.5 External Compliance Impacts

resources\questions\q_common_themes_in_ai_regulation_02.question.xml

Copyright © CompTIA, Inc. All rights reserved.